Fakultät
Angewandte Informatik



FALLBEISPIEL

ISMS Leitlinie

ChemoDemo AG

Fantasiestr. 1

4711 München

im Folgenden kurz ChemDemo genannt

Dok.nr.: ISMS-0001
Datum: 1.10.2021
Autor: OT-CISO, IT-CISO
Status: gültig

1. Inhalt

1. Inhalt 1
2. ISMS Leitlinie 1

2. ISMS Leitlinie

(auf Basis „Ganzheitliches Management der Informationssicherheit Taschenbuch“ – 19. September 2008, von Udo Adlmanninger, Herbert Pröll, Lars Rudolff, Michael Silvan, Michael Spreng, Thomas Störtkuhl, SecuMedia, ISBN-10: 3922746772)

Vorwort des Vorstands

Der sichere Umgang mit den geschäftskritischen Unternehmensdaten und den für die Kunden sicherheitsrelevanten Informationen ist unabdingbare Voraussetzung für den langfristigen Geschäftserfolg der ChemoDemo AG.

Primäres Ziel der auf organisatorischer und technischer Ebene umgesetzten Schutzmaßnahmen ist, die ChemoDemo AG und seine Kunden vor Schäden zu bewahren, die stetige Arbeitsfähigkeit der Mitarbeiter sicherzustellen, Datenverluste zu verhindern und etwaige Störungen so zu beherrschen, dass langzeitige Ausfälle vermieden werden und Mensch und Umwelt nicht geschädigt werden.

Hierzu gehört in erster Linie die Umsetzung eines Information Security Management und eines Business Continuity Management Systems.

Aufgabe aller Mitarbeiter ist es, den Grad und die Qualität an Sicherheit und Verfügbarkeit zu gewährleisten, die unsere Kunden und Geschäftspartner von uns erwarten und die wir entsprechend unseres Geschäftsauftrags sicherstellen müssen.

Der Vorstand trägt die Gesamtverantwortung für ein ausreichendes und fachlich wie wirtschaftlich angemessenes Information Security Management und Business Continuity Management System, um Schäden von der ChemoDemo AG abzuwenden und den langfristigen Geschäftserfolg zu gewährleisten. Unterstützt wird der Vorstand durch Beauftragte zur Informationssicherheit, Business Continuity sowie zum Datenschutz.

15.3.2020
Vorstand

Zielstellung

Die vorliegende Sicherheitspolitik beschreibt die wesentlichen Rahmenbedingungen des Informationssicherheits-Managementsystems für IT und OT von ChemoDemo.

Primäres Ziel der auf Prozessebene, organisatorischer und technischer Ebene und bzgl. der Mitarbeiterinnen umgesetzten Schutzmaßnahmen ist, ChemoDemo und seine Kunden vor Schäden zu bewahren, die stetige Arbeitsfähigkeit der Mitarbeiter sicherzustellen, Datenverluste zu verhindern und den Betrieb sowohl der IT als auch der OT und damit der Produktion zu gewährleisten.

Implementiert in die Aufbau- und Ablauforganisation der ChemoDemo AG wird die vorliegende Sicherheitspolitik durch die ihr nachgeordneten Sicherheitsrichtlinien und Arbeitsdokumente.

Gültigkeit
seit März 2020

Geltungsbereich
Die vorliegende Sicherheitspolitik ist verpflichtend für alle Mitarbeiter der Geschäfts- und Organisationseinheiten der ChemoDemo AG, aber auch für die Mitarbeiter von Partnern der ChemoDemo AG, die im Auftrag der ChemoDemo AG tätig sind oder handeln.

Historie

Version	Datum	Kommentar
1.0	März 2020	Finale Version

Freigabe und Review
Die Sicherheitspolitik erfährt Gültigkeit mit der Freigabe der Version 1.0 durch den Vorstand. Informationseigentümer ist der Vorstand der ChemoDemo AG.
Die Sicherheitspolitik der ChemoDemo AG ist durch den Beauftragten für Informationssicherheit bzw. Business Continuity bedarfsorientiert an eventuelle Änderungen anzupassen.
Die vorliegende Sicherheitspolitik ist spätestens im Jahr 2024 durch den Beauftragten für Informationssicherheit bzw. Business Continuity einem weiteren Review zu unterziehen und mit dem Vorstand abzustimmen.

Begriffsbestimmung und Definitionen
Begriffe und Definitionen finden sich unter <Link auf das Intranet zum Glossar>.

Anforderungen bzgl. Business Continuity
Siehe [CD-BCMS-0001-Handbuch]

Anforderungen an die Sicherheit
Der sichere Umgang mit Informationen und Daten ist unabdingbare Voraussetzung für den langfristigen Geschäftserfolg der ChemoDemo AG.
Besonderen Schutz genießt die produktive OT-Umgebung der ChemoDemo AG. Änderungen sind über die vorgegebenen Prozesse autorisiert durchzuführen.
Sicherheit wird dabei als fortlaufender Prozess der schrittweisen Verbesserung der Qualität im Sinne eines kontinuierlichen Verbesserungsprozesses verstanden.

Sicherheitsziele

Z1. **Schutz der Werte**
Die ChemoDemo AG schützt ihre Werte gegen Gefahren durch eine ganzheitliche Architektur für Informationssicherheit

Z2. **Verantwortung für den Schutz der Werte**
Für jeden geschäftsrelevanten Prozess, jede Anwendung, Komponente und jedes System sowie alle Dokumente, Daten und sonstige Informationen ist eine verantwortliche Person benannt.

Z3. **Gewährleistung der Nachweisbarkeit**
Jede Aktivität, für die eine gesetzliche Nachweispflicht besteht, wird entsprechend den Anforderungen nachweisbar protokolliert. Alle geschäftskritischen Dokumente, Daten und Informationen sind in rechtsverbindlicher Form (z.B. in Papierform) abzulegen und entsprechend den einschlägigen Aufbewahrungsfristen zu archivieren.

Z4. **Vorbereitung auf Störungen und Notfälle**
Es sind rechtzeitig Vorkehrungen für den Umgang mit Störungen und Einschränkungen im IT- und OT-Betrieb zu treffen, um Stör- und Notfälle innerhalb der definierten maximalen Wiederanlaufzeit zu beheben und mit möglichst geringem Schaden zu überstehen. Die Wiederanlaufklassen sind im Dokument [CD-BCMS-0003-Notfallmanagement] definiert. Es sind Notfallprozesse zu implementieren und zu dokumentieren.

Z5. **Sicherheitsbewusstsein**
Das Sicherheitsbewusstsein der Mitarbeiter ist Basis unserer Arbeit in allen Bereichen der ChemoDemo AG.

Sicherheitsprinzipien

Die folgenden allgemeinen Prinzipien der IT/OT-Sicherheit dienen sowohl als Vorgabe für die nachgeordneten Sicherheitsrichtlinien als auch zur Orientierung der Mitarbeiter im Entscheidungsfall.

P1. Verfügbarkeit vor IT/OT-Sicherheit

Der Informationsschutz, die Abwehr von Risiken und die Bekämpfung von Schäden ist zwar von hoher Bedeutung, dennoch geht die Verfügbarkeit der Systeme, Anwendungen und Daten im OT-Bereich vor die IT/OT-Sicherheit, um wo immer möglich einen Produktionsstillstand zu verhindern. Versorgungssicherheit steht an oberster Stelle.

P2. Safety vor IT/OT-Sicherheit, IT/OT Sicherheit für Safety

Maßnahmen der IT/OT Sicherheit dürfen die Safety nicht beeinträchtigen. Die Safety ist zudem besonders vor Cyber-Angriffen durch IT/OT Maßnahmen zu schützen.

P3. 4-Augenprinzip

Geschäftskritische Vorgänge sind durch mindestens zwei voneinander unabhängige Instanzen zu genehmigen. Gesetzliche Anforderungen bzgl. Rollentrennung zu identifizieren und umzusetzen.

P4. Minimalprinzip oder Need-to-Know-Prinzip
Die Ausgestaltung von Prozessen, Systemen und Anwendungen, insbesondere der Zugriff auf Daten und Informationen ist auf das Mindestmaß des Erforderlichen zu beschränken.

P4. Verbotsannahme mit Erlaubnisvorbehalt
Im Zugriff auf IT-Systeme, IACS (Industrial Automation and Control System), Anwendungen, Daten und Informationen gilt als verboten, was nicht explizit im Rahmen der Tätigkeitsbeschreibung oder eines expliziten Auftrags erlaubt ist.

Sicherheitsorganisation
Die Sicherheitsorganisation von ChemoDemo ist in [CD- ISMS-0002-Organisation] beschrieben.

Vorstand
Der Vorstand trägt die Gesamtverantwortung für die Sicherheit in der ChemoDemo AG. Er erlässt Richtlinien und Anweisungen zur Sicherheit.

Regelmäßiges Review
Das Informationsmanagementsystem (ISMS) ist regelmäßig auf seine wirksame Umsetzung hin zu überprüfen und zu kontrollieren. Dies umfasst sowohl das Regelwerk des ISMS selbst als auch die Kontrolle der im Rahmen des ISMS umgesetzten Schutzmaßnahmen, Policies und Prozesse.

Sicherheitsdokumentation
Die ChemoDemo AG dokumentiert sein internes Informationssicherheits-Managementsystem (ISMS) auf folgenden hierarchischen Dokumentenebenen:

- Security Policy
- Sicherheitsrichtlinien
- Sicherheitskonzepte, Verfahrensbeschreibungen und Handlungsanweisungen, Betriebshandbücher und Installationsanleitungen

Alle Dokumente sind im Intranet verfügbar.

Weitere Angaben zum Dokument

Stichworte
ISMS, Informationssicherheit, Managementsystem, Sicherheit, Politik, Sicherheitspolitik, Sicherheitsarchitektur, Geschäftsführung, Vorstand, Organisation, Sicherheitsorganisation, CSO, CISO, Dokumentation, Richtlinie

Weiterführende Dokumente
Folgende Dokumente wie Sicherheitsrichtlinien etc. finden Sie unter:
<Link zu den entsprechenden Dokumenten>